SECURITY · CHECKLIST · #SOC2 · #DATAGOVERNANCE · #CROSSBORDER · #CCPA · #AGENTICCOMMERCE

AI cross-border requirements: a scannable checklist

Every guarantee an AI cross-border service owes, the SOC 2 criterion it sits under, and the evidence a reviewer will ask for — in tables.

How to use it: **each row is a guarantee, the SOC 2 criterion it falls under, and the evidence**

---

a reviewer will ask for. SOC 2 is a **procedural assessment of how an organisation operates**, reported by an independent CPA firm — not a certification of a product or a database. The full definition, and why AI transport widens its scope, is in The AI ladder, §7 "SOC 2: what AI transport puts in scope".

1. Data governance

GUARANTEE	SOC 2 CRITERION	EVIDENCE TO SHOW
Know what personal data exists and where it lives	Confidentiality C1.1	Data inventory per system; the **country** each store is in
Consent **before** processing, per jurisdiction	Privacy P2–P3	Jurisdiction resolved from location (not language); one consent event per grant, with the wording version
Collect only what the purpose needs	Privacy P3	Field list per form; free text treated as personal data
Retention limits **enforced by a job**, not only a policy	Confidentiality C1.2 · Privacy P4	The scheduled job, its period, its last successful run
Erasure reaches every copy — including AI stores	Privacy P4	A deletion request traced through database, files, vector index, agent memory, prompt logs, ad platforms
Data-subject access on request	Privacy P5	A lookup that finds a person's rows without exposing others
Subprocessors named, with where each processes	Privacy P6 · CC9.2	The published list; each provider's own report

2. Transport

GUARANTEE	SOC 2 CRITERION	EVIDENCE TO SHOW
Encryption in transit everywhere	CC6.7	HTTPS-only configuration; no plaintext endpoints
Field-level encryption, keys held apart from the data	CC6.1	The database holds ciphertext; the key lives elsewhere
Keys rotated, never passed around	CC6.1	Rotation record by fingerprint — never the value
Secrets never written to logs	CC6.1 · CC7.2	Request logging off where a secret or key crosses the wire
Every cross-border flow **named and switchable**	Privacy P6	An itemised disclosure per flow, and a way to suspend one flow without stopping the site
Where data lives is a **setting of the deployment**, not code	CC8.1	Per-instance configuration; a changed residency changes who is asked to consent

3. Horizontal scaling and availability

GUARANTEE	SOC 2 CRITERION	EVIDENCE TO SHOW
No single point of failure in the answer path	Availability A1.1	A second path that answers when the primary is down
Writes survive a component outage	Availability A1.2	Buffered writes replayed in order after recovery
Retries never double-charge or double-order	Processing Integrity PI1.3	Idempotency keys; payment replay guards
Capacity measured, not assumed	Availability A1.1	A load test, or recorded limits per provider and region
Failures detected and alerted	CC7.2	Logged reasons for every refusal; an alert that someone receives
Changes pass a test gate	CC8.1	The release gate; deploys tagged to a commit

4. AI-specific

GUARANTEE	EVIDENCE TO SHOW
The model provider does not train on your data	The provider's terms for the product and plan used
Inference runs where the data is allowed to go	Region per model; personal data never sent to a global endpoint
The agent cannot decide permissions	Permission checked in the endpoint; the agent acts only under a signed, capped, revocable mandate
Prompt, output and memory logs follow the same retention and erasure	A period per AI store, and erasure proven against each
Wrong answers are caught, escalated and corrected	A score threshold that refuses weak answers; a human escalation path with tiers
Model, prompt and adapter changes are controlled	Versioned, reviewed, gated like code

5. Rules on the server vs rules in the theme

An AI agent has no browser. Anything decided in theme code — a Liquid condition, a script, a hard-coded attribute — is invisible to an agent, a scheduled job and a webhook, and editable by anyone who can reach the page. So permissions, data updates and every value an agent or a feed will read must be **decided server-side from rules and data**, and only **displayed** by the theme.

Permissions and data updates

CONCERN	RULES-BASED, SERVER-SIDE (CAPABILITIES · CLAIMS · EXTRAS)	HARD-CODED IN THE FRONT-END THEM
Who may do what	Resolved **per request** from the subject's claims and capability rows	`if` conditions in theme scripts or templates
An agent updating data	The agent calls an endpoint that checks the **capability and a signed mandate**, then the server writes	The agent fills in forms or replays page requests
Revoking access	One row changes; effective on the **next** request	A theme redeploy, plus cached pages that keep the old rule
Preferences and extras (language, market, consent flags)	Stored as claims/extras; read by every caller the same way	Held in theme variables or cookies
Consent	Decided at the edge from where the visitor **is**, before anything loads	A banner that hides and shows elements
Change control	Rules are data with a version and a test gate	Edits to theme files, often outside review
Audit	Every grant and refusal logged with its reason	Nothing

Values that must be codes, not text

VALUE	SERVER-SIDE (DECLARED, CODED)	HARD-CODED THEME TEXT	WHAT GOES WRONG
Language and region (`hreflang`)	Generated from the market registry as **ISO 639-1 language + ISO 3166-1 country** (`ko-KR` , `en-US`) plus `x-default`	Hand-written values such as `korean` , `en` alone, or one list pasted into every theme	Search engines ignore invalid values; adding a market means editing every theme; pages point at each other inconsistently
Country and jurisdiction	ISO 3166-1 / 3166-2 (`KR` , `US-CA`) resolved from **location**, never from language	Inferred from the page language or a dropdown	A Korean speaker in California gets Korean consent rules — the wrong law
Currency	ISO 4217 (`KRW` , `USD`); one canonical currency stored, display converted	A currency symbol typed into the theme	"₩" and "$" rendered from the wrong base; rounding and tax on the wrong amount
Weights and measurements	Value **with a declared unit** (e.g. `1.5 kg` , `60 mm`), from one product record	A bare number in a template (`1.5`)	Carriers rate the wrong parcel; feeds reject or misread it; net content is a legal declaration
Area and regional units	Canonical unit stored (m²); regional units (평, ft²) **derived** for display	Each market's page with its own typed number	The same floor priced three ways

State management

STATE	SERVER-SIDE	FRONT-END ONLY	WHAT GOES WRONG
Cart, order, payment status	Server records keyed by a server id; the page only displays them	`localStorage` or theme variables	Lost on another device; forgeable; invisible to agents and support
Consent and preferences	An append-only log plus current claims	A cookie the theme reads	No evidence; cleared cookies silently reset a legal choice
Loyalty points and tier	Derived from a ledger on read	A number stored in the page or a customer tag	Balances drift; a tier outlives the points that earned it
Rate limits and retries	Server keys and idempotency	Disabled buttons	Double orders when the button is re-enabled or bypassed

What server-side costs: a service that must be running, a network round trip per decision, and rules someone has to maintain as data. The theme stays fast because it only displays; the trade is that every rule has exactly one home, and it is not the page.

6. Cross-channel: the same rules on every channel

Mobile, browser, household, point of sale and desktop each capture data differently, but a channel is **not** a permission. Every channel sends inputs to the same server, which applies the same consent, capability and mandate rules — so what an AI can see or do never depends on which door the data came through.

CHANNEL	IDENTITY AND CONSENT CAPTURED	WHERE STATE LIVES	TRANSPORT TO THE SERVER	WHAT AN A
Mobile (installable web app, native shell)	Signed-in subject; consent asked by jurisdiction on first use	Server; the device caches only the app shell, never consent or orders	HTTPS; offline actions queued and replayed idempotently	Only what claims allo cached on authoritati
Browser	Same as mobile; bot check on every submission	Server; cookies hold a session reference, not decisions	HTTPS; field-level encryption before storage	Same as r
Household (shared device, shared account, family members)	**Per person**, not per device — each member's consent and claims are their own	Server, keyed to the person, with the household as a relationship	Same as browser	Recomme use house only where consent al
Point of sale (store terminal)	Staff identity for the terminal; customer identity only when the customer offers it	Server; the terminal holds a scoped key, not customer data	Scoped event keys — e.g. a terminal may **read** consent, not **write** product data	May read customer purpose; r enrich
Desktop (installed app)	Same as browser — the app shows the hosted page	Server; the app stores nothing sensitive	HTTPS to the same endpoints	Same as b
Agent (AI acting for a subject)	The subject's claims, passed for one step, never stored by the agent	Server	Tool calls to the same endpoints, each checked	Only unde **capped, sc boxed, rev**

RULE THAT HOLDS ACROSS CHANNELS	WHY
Consent follows the **person and their location**, not the device or channel	A household tablet and a store terminal must not widen what one person agreed to
The server is the only place a decision is made	A channel that decides for itself becomes the weakest channel
Every channel's data carries the same codes (ISO country, language, currency, units)	Otherwise the same customer is a different record per channel
AI visibility is granted per purpose, not per channel	"The agent can see POS data" is not a rule; "the agent may read consent status for purpose X" is
Erasure reaches every channel's copies	Including terminal logs, device caches, agent memory and ad platforms

7. US integration-platform (ERP/CRM middleware) fees

Only MuleSoft's entry price and Boomi's pay-as-you-go are published by the vendors; every other figure is a third-party estimate. **Get a quote.**

PLATFORM	PUBLISHED / REPORTED PRICING	MODEL
MuleSoft (Salesforce)	From **$2,000/month, billed annually** (official). 2026 packages priced by Mule flows and messages; legacy vCore plans reported at ~$1,250–$1,750 per vCore per month; premium connectors ~**$10k–$15k each per year** (Automation Atlas, Integrate.io)	Quote above entry
Boomi	Pay-as-you-go **$99/month + $0.05 per message** (official); committed editions quote-only, reported **$50k–$190k+/year**, total cost often **2–3× licence** (Automation Atlas)	Per message, or annual contract
Celigo	No list price; reported **~$1,000–$1,500/month** small, **$5,000+/month** enterprise (~$12.8k–$73k/year by company size) (Vendr, Integrate.io)	Quote, by flows and endpoints

What the fee does not include: the controls in §1–§6. A middleware platform moves data; the consent, retention, erasure and residency evidence is still the organisation's to produce.

8. Retention and consent gaps that become penalties (US)

SYSTEM	WHAT TO CHECK	WHY IT MATTERS
Email / SMS marketing platform (e.g. Klaviyo)	Whether it offers a retention period per data type; how deletion treats suppression lists; where exports are kept	Old events keep powering segments and retargeting unless something purges them
CRM (e.g. Salesforce)	Deleted records stay in the Recycle Bin **15 days**; field history is kept **18–24 months** (longer is an add-on); whether marketing data extensions carry a retention setting	Consent recorded in one cloud does not stop a send or sync in another unless it is enforced there too
Agent runtimes (e.g. Google ADK / Agent Engine)	Whether sessions and memory are reached by your erasure process	An erased customer's words can survive in agent memory
Google Ads / Merchant Center	Customer Match needs consented data; EEA traffic needs **Consent Mode v2** (`ad_user_data` , `ad_personalization`); the Merchant loyalty member API takes **unhashed** email and phone; YouTube affiliate reporting **must not be joined with personal or CRM data**	Policy breaches lead to account suspension
Retargeting	Cross-context behavioural advertising is "**sharing**" under CCPA/CPRA: honour **Global Privacy Control** and "Do Not Sell or Share"	**$2,663 per violation; $7,988 intentional or involving under-16s** (2025 figures, CPPA), assessed per consumer; breach private actions **$107–$799 per consumer**. Sephora paid **$1.2M** (2022)
Video pages	Ad pixels on pages that play video can trigger the **Video Privacy Protection Act**	Use a privacy-enhanced player and keep ad pixels off video pages without consent

9. The one-line summary per section

SECTION	IF YOU REMEMBER ONE THING
Governance	Erasure must reach AI stores, not only the database
Transport	Where data lives is a deployment setting, and it decides who must consent
Scaling	A second answer path and idempotent retries, or availability is a hope
AI-specific	The agent never decides what it may do
Rules vs theme	Decide on the server from rules and ISO codes; the theme only displays
Cross-channel	A channel is not a permission; every channel meets the same server rules
Middleware fees	The fee moves data; it does not produce the compliance evidence
Penalties	Retargeting without honouring opt-out is priced per consumer